

1) Análise de Risco – Clínica de Saúde (12 valores | 60 min)

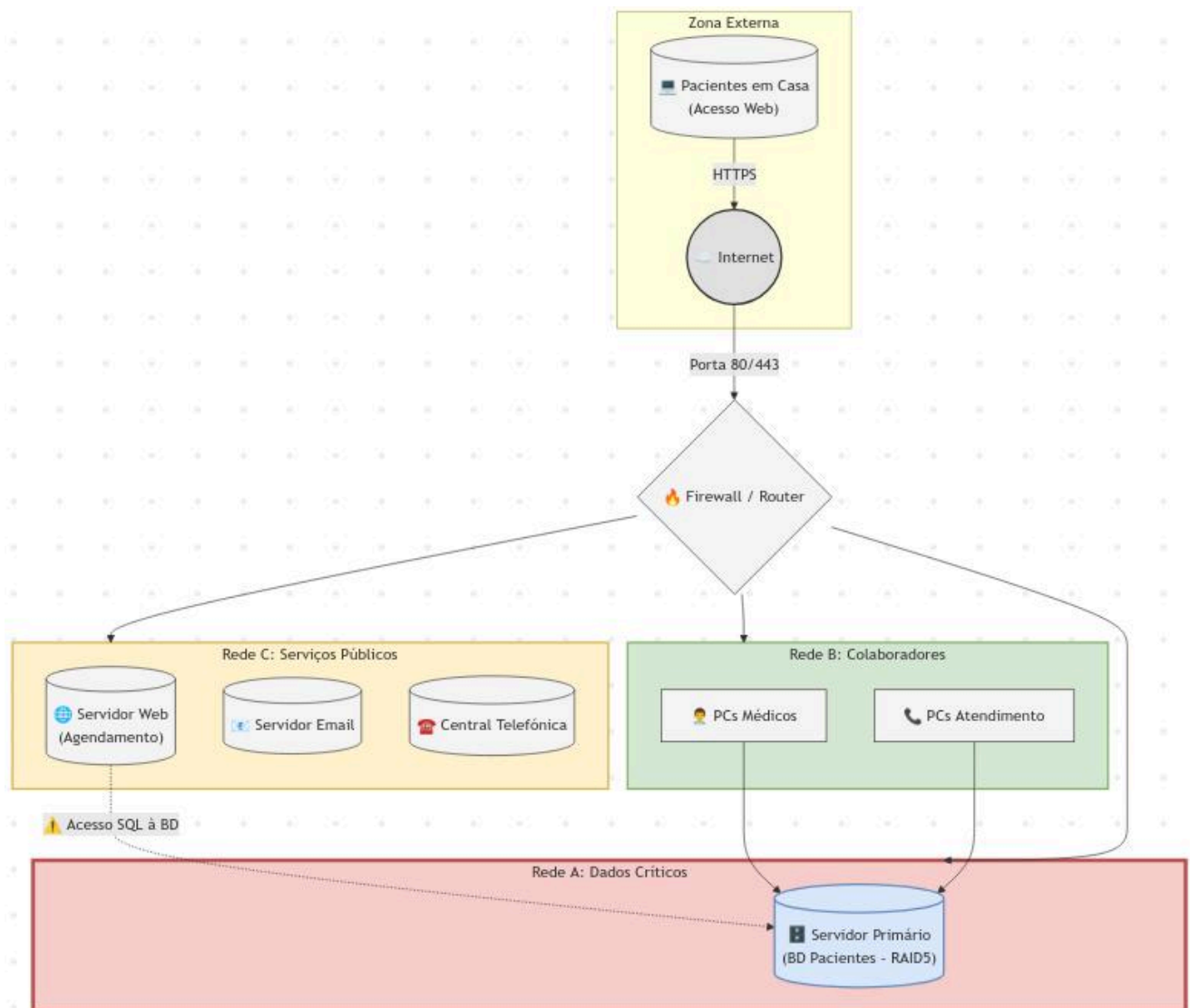
Considere uma rede informática instalada numa clínica de saúde localizada em Vila Real, contendo informação sensível de pacientes.

i) Esquema da rede

A infraestrutura da clínica encontra-se segmentada logicamente em três redes locais virtuais (VLANs), de forma a reduzir a superfície de ataque e melhorar a segurança:

- **Rede A (VLAN A):** afeta aos servidores, onde se encontra o servidor primário com a base de dados clínica, contendo informação sensível dos pacientes.
- **Rede B (VLAN B):** utilizada pelos colaboradores da clínica (médicos, enfermeiros e atendimento ao público).
- **Rede C (VLAN C):** contém os servidores de email, servidor Web e central telefónica.

O servidor Web, localizado na Rede C, possui acesso remoto controlado ao servidor da base de dados na Rede A, permitindo que os pacientes consultem exames e realizem marcações a partir de casa. O acesso externo é realizado através da Internet, protegido por um firewall que controla o tráfego entre as VLANs.



ii) Identificação de ameaças

Para o cenário apresentado, podem ser identificadas, entre outras, as seguintes ameaças:

1. Ataques externos ao servidor Web, como SQL Injection ou Cross-Site Scripting, com o objetivo de aceder à base de dados clínica.
2. Introdução de malware através de computadores dos colaboradores, comprometendo a rede interna.
3. Ataques de negação de serviço (DoS) ao servidor Web, causando indisponibilidade dos serviços.

4. Falhas elétricas prolongadas que afetem a sala de informática.
-

iii) Identificação de vulnerabilidades

As principais vulnerabilidades associadas ao sistema incluem:

1. Ausência de autenticação forte (ex.: multifator) no acesso aos sistemas críticos.
 2. Software desatualizado no servidor Web e nos sistemas dos colaboradores.
 3. Configuração excessiva de permissões de acesso à base de dados clínica.
 4. Falta de testes regulares aos mecanismos de backup e recuperação.
-

iv) Avaliação qualitativa de risco

A avaliação qualitativa de risco é realizada considerando a probabilidade de ocorrência das ameaças identificadas e o impacto resultante da exploração das vulnerabilidades existentes.

Dado que a clínica admite apenas um nível de risco **baixo**, e considerando que a informação tratada é sensível e protegida por legislação específica, os riscos com impacto elevado devem ser mitigados através da implementação de

controles adequados, de forma a reduzir o risco residual para níveis aceitáveis.

(A classificação detalhada do risco é realizada com base nas tabelas de avaliação qualitativa fornecidas em separado.)

v) Plano de tratamento de risco

Para os riscos identificados, define-se o seguinte plano de tratamento:

Risco 1 – Comprometimento do servidor Web

Tratamento: **Mitigação**

Controlos aplicados:

- Implementação de firewall aplicacional (WAF);
- Hardening do servidor Web;
- Atualizações e correções de segurança regulares.

Risco 2 – Perda ou corrupção de dados clínicos

Tratamento: **Mitigação**

Controlos aplicados:

- Implementação de backups regulares (full e incremental);
- Utilização de RAID para redundância de discos;
- Testes periódicos de restauro.

Risco 3 – Indisponibilidade do sistema informático

Tratamento: **Mitigação**

Controlos aplicados:

- Implementação de cluster de alta disponibilidade;
 - Uso de UPS e gerador de backup;
 - Monitorização contínua dos serviços críticos.
-

2) Cloud – Vantagens e Desvantagens (2 valores | 10 min)

A utilização de sistemas Cloud apresenta várias vantagens para as organizações. Entre as principais destacam-se a escalabilidade, a redução de custos iniciais em infraestrutura, a elevada disponibilidade dos serviços e a facilidade de manutenção e atualização por parte do fornecedor.

Como exemplo, uma base de dados alojada na cloud pode beneficiar de replicação geográfica, aumentando a disponibilidade do serviço.

No entanto, existem também desvantagens associadas à cloud, nomeadamente a dependência do fornecedor, questões legais relacionadas com a localização dos dados, dependência da conectividade à Internet e menor controlo direto sobre a infraestrutura.

3) Importância de um Plano de Continuidade de Negócio (2 valores | 10 min)

Um plano de continuidade de negócio define os procedimentos que permitem a uma organização continuar a operar após a ocorrência de um incidente ou desastre.

A sua importância reside na minimização do impacto no negócio, na proteção da reputação da organização e na garantia da continuidade dos serviços críticos. Este plano baseia-se na realização de uma Análise de Impacto no Negócio (BIA) e inclui a definição de métricas como RTO e RPO, bem como a elaboração do Plano de Continuidade de Negócio (BCP) e do Plano de Recuperação de Desastres (DRP).

4) Backups tornam RAID desnecessário? (2 valores | 10 min)

Não. O uso de backups não torna desnecessária a utilização de esquemas RAID.

O RAID permite garantir disponibilidade e tolerância a falhas de discos, enquanto os backups permitem recuperar dados em situações como erro humano, ataques de malware ou corrupção de dados. Assim, RAID e backups são tecnologias complementares e devem ser utilizadas em conjunto.

5) Avaliação Quantitativa e Plano de Tratamento de Risco (2 valores | 10 min)

A avaliação quantitativa de risco pode influenciar diretamente o plano de tratamento de risco, uma vez que permite traduzir o risco em valores monetários.

Ao calcular métricas como a Annualised Loss Expectancy (ALE), é possível comparar o custo potencial do risco com o custo de implementação dos controlos de segurança. Por exemplo, se um risco apresenta uma perda anual estimada de 10 000 € e o custo do controlo é de 3 000 €, a implementação do controlo é economicamente justificada.

Desta forma, a avaliação quantitativa apoia a tomada de decisão e a definição do plano de tratamento de risco.